

TRAINING @ FORREST ONE

Session 12 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Governance, Risk, Compliance & Exam Consolidation

The final session: how security is governed, how risk becomes a decision, how compliance is proved, and how users become part of the defence.

LESSONS 14-16

GOVERNANCE

RISK & COMPLIANCE



CHAPTER 1 · GOVERNANCE FOUNDATIONS

The capstone: governance sets direction

- **Where we are** the final session, and the step back from technical controls
- **How security is governed** governance sets direction, rules and accountability
- **What follows** risk end to end, then vendors, compliance and awareness
- **The shift** security becomes an organisational discipline, not a set of tools
- **Your habit** always ask what the business has decided, and why
- **The exam** Domain 5 is 20% of the paper, and the vocabulary is precise

One question keeps you useful

Keep asking what the business has decided and why.



CHAPTER 1 · GOVERNANCE FOUNDATIONS

Why governance comes first

- **Aligns security with the business** so security is never implemented in isolation
- **Directs the investment** targets spending at the assets the business depends on
- **Sets the risk appetite** everything else in the programme must respect it
- **A breach is expensive** and so is security that protects nothing that matters
- **The example** a financial institution prioritises data protection and compliance
- **That is how security earns its budget** protect what the business rests on



CHAPTER 1 · GOVERNANCE FOUNDATIONS

Structures, authority and accountability

Element	What it means
Security committee	Cross-functional: information technology, legal, human resources, operations
Reporting lines	Security reaches the chief executive or the board
Executive oversight	Tone at the top: direction, resources and review
Authority	The documented power to decide, approve or authorise
Accountability	Answering for the outcome, reinforced by audits

Two words the exam separates

Authority is the power to decide; accountability answers for the outcome.



CHAPTER 1 · GOVERNANCE FOUNDATIONS

Executive roles and oversight

- **Chief Information Security Officer** shapes strategy, develops policy, manages risk
- **The bridge role** translates technical problems into language executives can act on
- **Security directors** report to the CISO, own domains, help plan response and recovery
- **The board of directors** ensures a strategy exists and is genuinely implemented
- **Oversight in practice** reviews policy, tests risk management, keeps the organisation accountable



CHAPTER 1 · GOVERNANCE FOUNDATIONS

Operational roles and data ownership

Role	Responsibility
Security analyst	Monitors for threats, analyses security data, investigates incidents
Security administrator	Runs firewalls, intrusion detection and antivirus, runs audits
Security architect	Designs the security framework and integrates it
Data owner	Classifies data, decides who may access it and how it is protected
Data custodian	Implements the controls: encryption, access control, backups

Why the list matters

Clear roles prevent gaps and duplication, because every control has an owner.



CHAPTER 1 · GOVERNANCE FOUNDATIONS

The four governance document types

Type	Nature	Example
Policy	High-level statement of management intent	We protect customer data and obey the law
Standard	Mandatory, specific and measurable	Passwords of at least twelve characters, mixed
Guideline	Recommended practice, not mandatory	How to configure a firewall well
Procedure	Step-by-step instructions	The steps for conducting a security audit

The document lifecycle

Every document is developed with stakeholders, approved by the right authority, distributed, and then reviewed so it stays current.



DISCUSSION

A password 'standard' says twelve characters minimum; a 'guideline' suggests passphrases. What is the difference in force?

Probe: the standard is mandatory, and audits measure it; the guideline is recommended, and departures are acceptable if justified.

Standards are measured; guidelines are advisory.



CHAPTER 2 · EXTERNAL OBLIGATIONS

Regulatory requirements

Regulation	Sector or region	Core requirement
HIPAA	United States healthcare	Safeguard electronic protected health information
PCI DSS	Card payments	Secure the environment handling card data
NERC CIP	Energy	Protect critical infrastructure
GDPR	European Union	Protect personal data of EU citizens
CCPA	California	Rights over personal information

External becomes internal

External obligations become internal policy, and policy becomes controls.



CHAPTER 2 · EXTERNAL OBLIGATIONS

Contractual obligations

- **Service level agreements** can mandate controls, encryption standards and response times
- **Data processing agreements** define processor and controller duties, with audit rights
- **Partnership agreements** may require both sides to follow one shared framework
- **The common baseline** the NIST Cybersecurity Framework is often named in contracts
- **The consequence** customers can impose requirements, and failing them breaks the contract



CHAPTER 2 · EXTERNAL OBLIGATIONS

Legal considerations

- **Liability** legal action from affected parties and penalties from regulators
- **Due diligence** documenting the reasonable steps you took reduces your exposure
- **Jurisdiction** a multinational answers to the law of every place it does business
- **Privacy law** privacy by design, impact assessments, often a protection officer
- **The flow** external requirements are assessed, built into policy, audited, updated



CHAPTER 2 · EXTERNAL OBLIGATIONS

How you find risks

- **Asset inventory first** physical, digital and human resources; list it before you protect it
- **Why it matters** key servers, databases and personnel each carry vulnerabilities
- **Threat modelling** a structured question: how could this be attacked, and at what cost
- **The example** a web application model names injection attacks and maps how they occur
- **Vulnerability assessment** scanning tools find known weaknesses, such as outdated software
- **The rule** you cannot manage a risk you have never named



CHAPTER 2 · EXTERNAL OBLIGATIONS

Likelihood, impact and two methods

Element	Basis	When it is used
Likelihood	Probability, judged from the threat landscape and past incidents	Every assessment
Impact	Financial loss, reputational damage, operational disruption	Every assessment
Qualitative	Ratings: high, medium, low	Fast triage, no hard data
Quantitative	Money and probabilities	Expensive decisions, good data

Both, usually

Qualitative is quick and ideal for triage; quantitative is precise but data hungry.



CHAPTER 3 · RISK ANALYSIS AND TREATMENT

The calculation, step by step

Term	Meaning	Figure
Asset value	Worth of the asset to the business	100,000
Exposure factor	Percentage lost if the risk occurs	40 percent
Single loss expectancy	Asset value times exposure factor	40,000
Annual rate of occurrence	Expected frequency each year	0.1, once in ten years
Annualised loss expectancy	Single loss expectancy times that rate	4,000

Say it in money and an executive will listen

Weigh the cost of a control against the loss it prevents.



CHAPTER 3 · RISK ANALYSIS AND TREATMENT

The register is a living document

- **What it describes** each risk and the circumstances under which it might occur
- **The rating** built from likelihood and impact, so attention goes to the top
- **The risk owner** one person or team accountable for managing that risk
- **Treatment status** monitored, mitigated, transferred or accepted
- **The scoring** qualitative, quantitative, or a hybrid of both
- **A living document** new risks added, ratings reassessed, stakeholders engaged



CHAPTER 3 · RISK ANALYSIS AND TREATMENT

Appetite and tolerance are not the same

- **Risk appetite** how much risk the organisation will pursue or retain
- **The contrast** a regulated bank has a low appetite; a young company accepts more
- **Risk tolerance** how far it may drift from that appetite before action is taken
- **The worked example** a five percent share loss accepted, but only two percent drift in a quarter
- **The line to remember** appetite sets the boundary; tolerance says how far you may drift



CHAPTER 3 · RISK ANALYSIS AND TREATMENT

The four responses

Strategy	Action	Example
Avoid	Eliminate the activity that creates the risk	Do not enter that volatile market
Transfer	Shift the risk to a third party	Cyber insurance, or outsourcing
Mitigate	Reduce likelihood or impact with controls	Firewalls, detection, training
Accept	Retain the risk, with sign off	When the control costs more than the impact

Match, then revisit

Each strategy fits a situation; match it to the organisation, then revisit it.



QUIZ

Activity: respond to the risks

- A legacy system cannot be patched. Which response, and how?
- Flood risk at a data centre. Which response?
- The board accepts a risk. What must be recorded?
- A supplier holds your most sensitive data. What does the contract require?
- Debrief: which response do organisations use most, and why?

Mitigate with compensating controls, or accept with sign-off; transfer via insurance; acceptance must be documented by management; contracts carry data handling, incident notice, audit rights and an exit plan.



BREAK
10 MINUTES

Back soon: risk reporting and business impact, then vendors, compliance, audit and awareness.



CHAPTER 4 · RISK REPORTING AND VENDORS

The same risk, three audiences

- **Technical teams** specific vulnerabilities, threat vectors, severity scores, patch timelines
- **Executives** operational, financial and strategic impact, in charts rather than logs
- **Board and regulators** compliance, governance and plain language
- **The format** live dashboards, detailed reports, short executive summaries
- **Useful metrics** frequency of occurrence, impact severity, mitigation status
- **The rule** report on a regular cycle and tailor the language to the reader

Risk only matters when someone acts on it

Reporting is a skill in its own right: one document for everybody fails.



CHAPTER 4 · RISK REPORTING AND VENDORS

Business impact analysis

- **What it identifies** the processes critical to operations, whose failure hurts most
- **Dependencies mapped** the systems, applications and people those processes rely on
- **Consequences assessed** financial, reputational and regulatory
- **Recovery priorities** the most critical functions are restored first
- **Resource allocation** people, technology and budget go where impact is greatest
- **Why it matters** that is how continuity planning earns its funding



CHAPTER 4 · RISK REPORTING AND VENDORS

Vendor assessment before contract

- **Security questionnaire** encryption, network security, incident response
- **Documentation review** their policies, procedures and any compliance reports
- **On site assessment** sees practice rather than claims, where it matters
- **Due diligence** financial stability, certifications, incident history, references
- **Depth follows risk** data sensitivity, access level and the vendor role set the scrutiny
- **Common markers of maturity** ISO 27001 and SOC 2 certifications



CHAPTER 4 · RISK REPORTING AND VENDORS

Contracts that carry security

Element	What to require
Data handling	Encryption standards, access controls, data segregation
Incident notification	Define the incident, and the deadline for telling you
Audit rights and agreements	Audit scope and frequency; master service, non disclosure
Service levels	Uptime, response times, compliance with a named standard
Exit	Data return and secure destruction on termination

Define it before you sign

Define what counts as a security incident, and the deadline to tell you.



CHAPTER 4 · RISK REPORTING AND VENDORS

Monitoring and rules of engagement

- **Periodic reassessment** checks the vendor still meets your requirements
- **Compliance verification** confirms they follow the rules that apply to them
- **Performance tracking** agreed indicators for quality, timeliness and reliability
- **Rules of engagement** the boundaries of what the vendor may access and do
- **Least privilege** enforced with role based access control and multifactor authentication
- **Escalation** a route to raise a problem, and a rehearsed vendor incident plan



CHAPTER 5 · COMPLIANCE, PRIVACY AND AUDIT

Frameworks and what applies to you

Framework	Covers	Applies to
PCI DSS	Cardholder data	Anyone handling card payments
HIPAA	Medical information	Providers, plans and clearinghouses
SOX	Financial reporting integrity	Publicly traded companies
GDPR	Personal data of EU citizens	Any organisation processing that data

Compliance is the proof, and a baseline

Decide what applies by industry, geography and data type: compliance is a baseline.



CHAPTER 5 · COMPLIANCE, PRIVACY AND AUDIT

Monitoring and demonstrating compliance

- **Automated tooling** a security information and event management system alerts on breaches
- **Configuration management** keeps systems on approved settings and reverses drift
- **Manual review** interpreting a regulation cannot be automated
- **Evidence** logs, audit trails and documentation that show controls working
- **Protect the trails** audit trails must resist tampering and unauthorised access
- **Reporting** regulators, auditors and management, with dashboards and metrics



CHAPTER 5 · COMPLIANCE, PRIVACY AND AUDIT

When compliance fails, and privacy duties

- **Fines** up to four percent of global turnover, or twenty million euro
- **Sanctions** regulators can restrict processing, and remove the licence to operate
- **Reputational damage** customers leave, and new ones stay away
- **Legal liability** lawsuits and increased regulatory scrutiny
- **Privacy duties** subject rights, informed consent and breach notification
- **Privacy by assessment** impact assessments find risk before processing begins



CHAPTER 5 · COMPLIANCE, PRIVACY AND AUDIT

Internal and external audits

Audit	Conducted by	Purpose
Internal	The organisation's own staff	Self assessment, improvement, preparation
External	An independent third party	Regulatory compliance, customer assurance
Stages	Both types	Planning, evidence, findings, remediation tracking

Reality against the paperwork

Both follow the same four stages: plan with scope, gather evidence, report findings, then track remediation until each issue is closed.



CHAPTER 6 · ASSURANCE AND AWARENESS

Attestation and penetration testing

- **SOC 1** controls relevant to financial reporting
- **SOC 2** security, availability, processing integrity, confidentiality, privacy
- **SOC 3** the same picture at a high level, for a general audience
- **Certification statements** for example a statement against ISO 27001
- **Penetration testing** attacking with permission: black box, white box or grey box
- **The cycle** scope and rules of engagement first, then remediate and retest

Attestation declares, testing proves

Attestation is a formal declaration that controls meet stated criteria.



CHAPTER 6 · ASSURANCE AND AWARENESS

Designing an awareness programme

- **Audience analysis** which roles touch sensitive data, what they know, where the gaps are
- **Objectives** specific, measurable and time bound, such as reporting a phishing email
- **Content** current and recognisable: real incidents, interactive scenarios, visual aids
- **Delivery** computer based for scale, instructor led for depth, campaigns for reminders
- **Tailoring** strategy for executives, depth for technical staff
- **Measurement** assessments, simulations and reported incidents



CHAPTER 6 · ASSURANCE AND AWARENESS

Phishing training and simulations

- **Recognition** odd sender, urgency, unexpected attachment, unfamiliar link
- **Reporting** one obvious route, such as forwarding to the security team
- **Simulations** designed, sent without warning, then analysed
- **Progressive difficulty** from obvious scams to business email compromise
- **Immediate feedback** explains what the user missed
- **The metrics** click rate down, reporting rate up, and watch the trends

Keep the pace reasonable

Too many simulations cause fatigue, and fatigue destroys the reporting habit.



CHAPTER 6 · ASSURANCE AND AWARENESS

Guidance, reporting and anomalies to report

Area	What to teach and expect
Guidance and reminders	Steps a person can follow today, plus tools such as a password manager
Reporting	A mailbox, a phone line, an anonymous portal, and thanks not blame
Social engineering	Unsolicited requests, impersonation, urgency, poor language
Insider threat	Unusual access, disgruntlement, data hoarding, bypassing controls
Physical	Escort strangers, no tailgating, lock unattended devices

Thank the person who reports

Punishment destroys your early warning, so thank the person who reports.



CHAPTER 6 · ASSURANCE AND AWARENESS

Measuring the programme and improving it

- **Assessments** quizzes that test recognition, not recall of slogans
- **Simulations** how users actually behave under a mock attack
- **Incident metrics** what users report, and how quickly they report it
- **Analyse** look for trends and gaps in the results
- **Refresh** recent incidents and current threat intelligence
- **Ask and vary** feedback from the audience, varied channels, staying visible

Awareness fades fast

A programme that never changes is measuring a threat that has moved on.



Data classification and data states

Class	Meaning	Example
Public	No restriction	Brochures, press releases
Internal	Internal use only	Procedures, plans
Confidential	Restricted	HR records, contracts
Restricted	Most sensitive	Trade secrets, health data

Classification drives the controls

The higher the class, the stronger the protection, and each of the three data states needs its own controls.



Data roles and the data lifecycle

- **Data owner** accountable for classification, access and protection
- **Data steward** ensures quality and governance day to day
- **Data custodian** implements the controls: encryption, access control, backups
- **The lifecycle** collect, store, use, share, archive, destroy
- **Retention policy** how long data is kept, and why: legal and business drivers
- **Secure destruction** at the end of retention: wiping or destruction of the media



Privacy law and data sovereignty

- **GDPR and UK GDPR** the EU and UK data protection frameworks
- **The principles** lawful, transparent, minimised, accurate, secure
- **The rights** access, rectification, erasure, portability, restriction
- **Consent and the breach duty** informed and freely given; notify within 72 hours
- **Sovereignty** data answers to the law of the jurisdiction where it resides
- **By data subject** GDPR and CCPA apply by the data subject's location



EXAM ALIGNMENT

What this maps to in the exam

Objective	What the exam tests
12.1 Governance	Policy, standard, guideline, procedure; roles and accountability; external obligations; compliance
12.2 Risk Management	Identification and assessment; register and appetite; the four responses; vendors; reporting and BIA
12.3 Data Protection	Classification; roles and lifecycle; privacy law and sovereignty
Assurance & awareness	Attestation and penetration testing; awareness design, phishing and reporting



KEY TAKEAWAYS

- **Governance sets direction** policy, standard, guideline, procedure.
- **Authority decides, accountability answers** and audits reinforce it.
- **Risk is registered, owned and costed** SLE and ALE put money on it.
- **Four responses** avoid, transfer, mitigate, accept.
- **Vendors extend your risk** assess, contract, monitor.
- **Compliance is a baseline** and audits prove it.
- **Awareness turns users into sensors** train, simulate, measure, refresh.



QUIZ

Check your understanding

- Open Quiz_Session_12.html in your browser.
- 20 questions, immediate feedback, exam-objective tag on every question.
- Read each explanation, because the distractors teach as much as the answer.
- Score 70%+ before moving on.

Every question maps to a CompTIA exam objective, e.g. 12.2 Risk Management.



COURSE COMPLETE

Your next step is the exam

- **Revise the five domains** from network models and cryptography to architecture, operations and this session
- **Revisit the session quizzes** all twelve, as a full sweep
- **Practise performance-based questions** sequencing and scenario decisions under time pressure
- **Book the exam** and sit it while the material is fresh
- **The pass mark** 750 on a scale of 100 to 900
- **Stay curious** the certification is the start, not the destination



NEXT SESSION

You are exam-ready

- General Security Concepts, sessions 1–2
- Threats, Vulnerabilities & Mitigations, sessions 3–5
- Security Architecture, sessions 6–7
- Security Operations, sessions 8–11
- Security Program Management, session 12
- Good luck, and stay curious.

